BarMatchIA

21.6.14 - Brief funcional: Alta y gestión básica de accesos

Insumo para diagrama UML - Capstone 2026-2

Objetivo

Permitir la creación, activación, asociación, recuperación y deshabilitación básica de cuentas y accesos en BarMatchIA, manteniendo una separación clara entre los perfiles Cliente, Personal del Local, Administrador del Local y Administrador de Plataforma.

Participantes

- Administrador de Plataforma.
- Administrador del Local.
- Personal del Local.
- Cliente.
- Aplicación BarMatchIA.
- Servicio de Autenticación y Autorización.
- Base de Datos / Persistencia.
- Servicio de Notificaciones.

Precondiciones

- BarMatchIA dispone de una estructura básica de usuarios, perfiles y asociaciones.
- El Administrador de Plataforma se encuentra autenticado y autorizado para gestionar accesos globales.
- Cuando se gestione Personal del Local, existe un establecimiento habilitado y un Administrador del Local asociado.
- Las acciones de alta, modificación o deshabilitación de accesos se realizan únicamente por usuarios autorizados.
- El Servicio de Notificaciones se encuentra disponible para confirmación de cuenta, recuperación de acceso y avisos relevantes.

Flujo principal A - Alta de Administrador del Local

1. El Administrador de Plataforma ingresa al módulo de gestión de establecimientos y accesos.
2. Selecciona un establecimiento existente o completa su creación inicial según el flujo administrativo correspondiente.
3. Selecciona la opción de asociar un Administrador del Local.
4. BarMatchIA solicita los datos mínimos de identificación y contacto requeridos para crear o asociar la cuenta.
5. El Administrador de Plataforma ingresa la información.
6. BarMatchIA valida que el identificador de acceso no se encuentre utilizado de forma incompatible.

7. El sistema crea la cuenta o reutiliza una cuenta existente válida, según las reglas que posteriormente se definan.
8. BarMatchIA asigna el perfil Administrador del Local y lo relaciona con el establecimiento correspondiente.
9. La cuenta queda en el estado de activación definido para nuevas altas.
10. El Servicio de Notificaciones envía al usuario la comunicación necesaria para confirmar o habilitar su acceso.
11. El usuario completa el proceso de activación.
12. El Servicio de Autenticación valida el acceso.
13. El Administrador del Local queda habilitado para ingresar únicamente a los establecimientos y funciones que tenga asignados.

Flujo principal B - Alta de Personal del Local

1. El Administrador del Local ingresa a la gestión de accesos de su establecimiento.
2. Selecciona la opción de crear o asociar Personal del Local.
3. BarMatchIA solicita los datos mínimos necesarios.
4. El Administrador del Local completa la información.
5. BarMatchIA valida que el usuario pueda asociarse al establecimiento.
6. El sistema crea o asocia la cuenta con el perfil Personal del Local.
7. La relación queda limitada al establecimiento autorizado.
8. El Servicio de Notificaciones envía la comunicación de activación cuando corresponda.
9. El usuario completa la activación y define sus credenciales según el mecanismo establecido.
10. El Personal del Local inicia sesión.
11. El Servicio de Autorización entrega únicamente las funciones operacionales permitidas para su perfil.

Flujo principal C - Registro de Cliente

1. El Cliente explora BarMatchIA sin necesidad de autenticarse.
2. Cuando intenta realizar una acción que requiere cuenta, selecciona registrarse.
3. BarMatchIA solicita los datos mínimos requeridos.
4. El Cliente completa el registro.
5. El sistema valida formato, unicidad y condiciones mínimas de la cuenta.
6. La cuenta se crea en estado pendiente de confirmación cuando corresponda.
7. El Servicio de Notificaciones envía el mecanismo de confirmación.
8. El Cliente confirma su cuenta.
9. BarMatchIA habilita el acceso.
10. El Cliente puede iniciar sesión y utilizar las funciones que requieren autenticación, como confirmar reservas, consultar historial o gestionar su cuenta.

Principio central

La identidad de un usuario y los permisos que posee son conceptos relacionados, pero distintos.

Una cuenta válida no debe entregar acceso por sí sola a funciones administrativas u operacionales. BarMatchIA debe autorizar cada acción según el perfil y las asociaciones vigentes del usuario.

Separación de perfiles y alcance

- Cliente: acceso únicamente a sus datos, reservas, historial y funciones destinadas al usuario final.
- Personal del Local: acceso operacional limitado a los establecimientos a los que se encuentre asociado.
- Administrador del Local: acceso de configuración, supervisión, BI, predicciones y gestión de accesos permitidos dentro de sus establecimientos.
- Administrador de Plataforma: acceso global para alta de establecimientos, asociaciones administrativas y gestión global controlada de cuentas y accesos, incluyendo consultas y correcciones administrativas excepcionales dentro de los permisos definidos.

La definición exacta de permisos se formalizará posteriormente mediante una matriz de autorización. En esta etapa se establece que el acceso debe responder al principio de mínimo privilegio.

Flujo alternativo A - Cuenta existente

1. Durante un alta, BarMatchIA detecta que el correo o identificador ya pertenece a una cuenta existente.
2. El sistema evita crear una cuenta duplicada.
3. BarMatchIA evalúa si la cuenta puede reutilizarse mediante una nueva asociación válida.
4. Si la asociación está permitida, solicita confirmación al usuario autorizado que realiza la gestión.
5. La nueva relación se registra sin duplicar la identidad.
6. Si la asociación no es válida, BarMatchIA informa el conflicto y no modifica los accesos.

Flujo alternativo B - Usuario intenta acceder sin permisos

1. Un usuario autenticado intenta acceder a una función o establecimiento no autorizado.
2. BarMatchIA consulta sus perfiles y asociaciones vigentes.
3. El Servicio de Autorización determina que no posee permisos suficientes.
4. La acción se rechaza.
5. La aplicación informa que el acceso no está autorizado sin exponer información innecesaria.
6. El intento puede quedar disponible para trazabilidad de seguridad cuando corresponda.

Flujo alternativo C - Recuperación de acceso

1. El usuario indica que no puede acceder a su cuenta.
2. BarMatchIA solicita el identificador requerido para iniciar recuperación.
3. El sistema valida que exista una cuenta compatible con el proceso.
4. El Servicio de Notificaciones envía un mecanismo temporal de recuperación al canal autorizado.
5. El usuario valida el mecanismo recibido.
6. BarMatchIA permite establecer una nueva credencial o recuperar el acceso mediante el procedimiento definido.
7. El mecanismo temporal deja de ser válido después de su uso o vencimiento.
8. El usuario puede volver a autenticarse.

Flujo alternativo D - Deshabilitación de acceso

1. Un usuario autorizado selecciona una cuenta o asociación que debe dejar de operar.
2. BarMatchIA verifica los permisos de quien solicita la acción.

3. El sistema muestra el alcance de la deshabilitación.
4. El usuario autorizado confirma la acción.
5. BarMatchIA deshabilita la cuenta completa o únicamente la asociación correspondiente, según el caso.
6. El usuario afectado deja de poder utilizar los accesos deshabilitados.
7. La acción conserva fecha, responsable y alcance para trazabilidad.

Deshabilitar una asociación con un establecimiento no implica necesariamente eliminar la identidad del usuario ni otras asociaciones válidas.

Flujo alternativo E - Reactivación

1. Un usuario autorizado consulta una cuenta o asociación deshabilitada.
2. BarMatchIA valida que la reactivación sea permitida.
3. El usuario confirma la acción.
4. El sistema restablece únicamente los accesos autorizados.
5. La reactivación queda registrada.
6. Cuando corresponda, el Servicio de Notificaciones informa al usuario.

Flujo alternativo F - Enlace de activación o recuperación inválido

1. El usuario intenta utilizar un mecanismo temporal de activación o recuperación.
2. BarMatchIA valida el token o mecanismo recibido.
3. Detecta que es inválido, ya fue utilizado o se encuentra vencido.
4. El acceso no se modifica.
5. La aplicación informa que el mecanismo ya no es válido.
6. El usuario puede solicitar uno nuevo cuando corresponda.

Relación con la gestión de establecimientos

El Administrador de Plataforma crea o habilita inicialmente el establecimiento y establece la primera asociación administrativa necesaria para que el Administrador del Local pueda continuar su configuración.

A partir de esa relación, el Administrador del Local gestiona ordinariamente las altas, asociaciones, habilitaciones, desactivaciones y reincorporaciones permitidas del Personal de sus propios establecimientos. El Administrador de Plataforma conserva capacidad global de consulta y corrección administrativa excepcional sobre cuentas y asociaciones, conforme a sus permisos, sin sustituir esta responsabilidad cotidiana del Administrador del Local.

Relación con seguridad y trazabilidad

La gestión de accesos es una función crítica de seguridad. El sistema debe evitar que una cuenta obtenga permisos por simple conocimiento de una URL, identificador de establecimiento o manipulación de parámetros.

- Autenticación para comprobar identidad.
- Autorización para validar cada acción.
- Mínimo privilegio.
- Separación entre cuenta y asociación a establecimiento.
- Tokens temporales para activación o recuperación.
- Trazabilidad mínima de altas, deshabilitaciones, reactivaciones y cambios críticos.
- Protección de credenciales y secretos mediante mecanismos que se definirán en arquitectura y seguridad.

Estado resultante

Cuenta creada o asociada -> perfil y alcance definidos -> activación/confirmación mediante Notificaciones -> autenticación válida -> autorización según perfil y establecimiento -> acceso habilitado; posteriormente puede recuperarse, deshabilitarse o reactivarse con trazabilidad.

Reglas funcionales identificadas

- RF-195: BarMatchIA debe mantener separados los conceptos de identidad, perfil y asociación a establecimiento.
- RF-196: El acceso a funciones debe validarse mediante autenticación y autorización.
- RF-197: El Administrador de Plataforma debe poder crear o asociar Administradores del Local a establecimientos.
- RF-198: El Administrador del Local debe poder crear o asociar Personal del Local dentro de los establecimientos que administra.
- RF-199: Un usuario no debe obtener acceso a establecimientos con los que no posea una asociación válida.
- RF-200: BarMatchIA debe evitar la creación innecesaria de identidades duplicadas cuando exista una cuenta reutilizable.
- RF-201: Una misma identidad podrá poseer más de una asociación únicamente cuando las reglas de autorización lo permitan.
- RF-202: El Cliente debe poder registrarse sin intervención administrativa.
- RF-203: La confirmación de cuenta debe utilizar un mecanismo temporal enviado mediante el Servicio de Notificaciones cuando corresponda.
- RF-204: Los mecanismos temporales de activación y recuperación deben ser de uso limitado y poseer vencimiento.
- RF-205: La recuperación de acceso no debe revelar a terceros información sensible de la cuenta.
- RF-206: Un usuario autenticado sin permisos suficientes debe recibir una denegación de acceso.
- RF-207: La deshabilitación puede afectar una cuenta completa o una asociación específica según el alcance de la acción.
- RF-208: Deshabilitar una asociación no debe eliminar automáticamente otras asociaciones válidas de la misma identidad.
- RF-209: Las altas, deshabilitaciones, reactivaciones y cambios críticos de acceso deben conservar trazabilidad mínima.
- RF-210: El acceso debe seguir el principio de mínimo privilegio.
- RF-211: El Personal del Local debe acceder únicamente a funciones operacionales autorizadas.
- RF-212: El Administrador del Local debe acceder únicamente a establecimientos y funciones bajo su administración.
- RF-213: El Administrador de Plataforma debe disponer de permisos globales controlados para administración, consulta y corrección administrativa excepcional de cuentas y accesos.
- RF-214: Las credenciales no deben almacenarse ni exponerse en texto plano.
- RF-215: La aplicación debe validar autorización en el servidor o componente de seguridad correspondiente y no depender únicamente de restricciones visuales de interfaz.

La nomenclatura RF se utiliza temporalmente como referencia de trabajo. Este flujo continúa la numeración cerrada en 21.6.13 e incorpora RF-195 a RF-215.

Decisiones pendientes para reglas de negocio, arquitectura y seguridad

- Datos mínimos definitivos para cada tipo de cuenta.
- Si el correo electrónico será el identificador principal de acceso.
- Mecanismo definitivo de autenticación.
- Política de contraseñas.
- Uso o no de autenticación multifactor para perfiles administrativos.
- Duración exacta de tokens de activación y recuperación.
- Matriz definitiva de permisos por perfil.
- Si un usuario podrá administrar más de un establecimiento con la misma cuenta.
- Si un Personal del Local podrá asociarse a más de un establecimiento.
- Permisos exactos del Administrador del Local para alta, baja y reactivación de Personal.
- Flujo de cambio de correo u otros identificadores críticos.
- Política de bloqueo por intentos fallidos.
- Gestión definitiva de sesiones.
- Política de auditoría de accesos y acciones administrativas.
- SSO o autenticación social como funcionalidad deseable posterior al MVP.
- Tecnología concreta de identidad, autenticación y autorización.
- Acciones exactas de consulta y corrección administrativa excepcional permitidas al Administrador de Plataforma sobre cuentas y asociaciones

Brief para diagrama UML

Tipo de diagrama sugerido: Diagrama de Secuencia UML.

Participantes mínimos

- Administrador de Plataforma o Administrador del Local, según el alta representada.
- Usuario que recibe el acceso.
- Aplicación BarMatchIA.
- Servicio de Autenticación y Autorización.
- Base de Datos / Persistencia.
- Servicio de Notificaciones.

Flujo principal recomendado para representar

Administrador autorizado solicita alta -> Aplicación solicita datos -> valida identidad existente -> Persistencia crea o asocia cuenta -> Servicio de Autorización asigna perfil/alcance -> Servicio de Notificaciones envía activación -> Usuario confirma -> Servicio de Autenticación habilita acceso -> Usuario inicia sesión -> Autorización valida perfil y establecimiento -> Aplicación permite únicamente funciones autorizadas.

Fragmentos alternativos mínimos

- Cuenta ya existente y reutilización mediante asociación.
- Usuario intenta acceder sin permisos.
- Recuperación de acceso.
- Deshabilitación de cuenta o asociación.
- Reactivación.
- Token de activación o recuperación inválido o vencido.

Regla crítica

Una cuenta autenticada no debe equivaler automáticamente a acceso autorizado. BarMatchIA debe validar perfil y asociación vigente para cada función protegida y mantener trazabilidad de los cambios críticos de acceso.

No representar todavía

- Proveedor de identidad definitivo.
- JWT, cookies, sesiones u otro mecanismo concreto.
- OAuth, OpenID Connect o protocolo definitivo.
- SSO o login social.
- MFA definitivo.
- Algoritmo o mecanismo concreto de hashing.
- Duraciones definitivas de tokens y sesiones.
- Endpoints específicos.
- Frameworks.
- Microservicios definitivos.
- Tecnologías concretas.
- Decisiones arquitectónicas aún no definidas.